

.....
1055 Budapest
Tel.: +36 1 391-1400
ugyfelszolgalat@naih.hu
Falk Miksa utca 9-11.
Fax: +36 1 391-1410
www.naih.hu

Ügyszám:
Előzmény:
Kapcs.:

NAIH-1245-29/2023
NAIH-8516/2022
NAIH-8390/2022

Tárgy:
döntés
hivatalból
induló
adatvédelmi
hatósági
eljárásban

H A T Á R O Z A T

A Nemzeti Adatvédelmi és Információszabadság Hatóság (a továbbiakban: Hatóság) az Educational Development Informatikai Zrt. (2023. április 20. napját megelőzően: eKRÉTA Informatikai Zrt.) (székhely: 1111 Budapest, Budafoki út 59., cégjegyzékszám: 01-10-140310) (a továbbiakban: Ügyfél vagy Kötelezett) adatkezelésével kapcsolatban a természetes személyeknek a személyes adatok kezelése tekintetében történő védelméről és az ilyen adatok szabad áramlásáról, valamint a 95/46/EK irányelv hatályon kívül helyezéséről szóló (EU) 2016/679 rendelet (a továbbiakban: általános adatvédelmi rendelet) 32-34. cikkeinek feltételezhető megsértése miatt 2022. november 11. napján az információs önrendelkezési jogról és az információszabadságról szóló 2011. évi CXII. törvény (a továbbiakban: Infotv.) 60. § (1) bekezdése alapján hivatalból indított adatvédelmi hatósági eljárásban az Ügyféllel szemben az alábbi döntést hozza:

A Hatóság

megállapítja, hogy

1) a) a Kötelezett nem tett eleget az általános adatvédelmi rendelet 32. cikk (1) bekezdés b) pontjában, valamint a 32. cikk (2) bekezdésében foglalt kötelezettségének azzal, hogy az informatikai fejlesztői környezetének adatbiztonsági beállításai során nem vette kellőképpen figyelembe az adatkezelésből eredő olyan kockázatokat, amelyek a személyes adatok jogosulatlan nyilvánosságra hozatalából vagy az azokhoz való jogosulatlan hozzáférésből erednek, és emiatt a személyes adatok kezelésére használt rendszerek és szolgáltatások folyamatos bizalmas jellegének biztosítását, integritását, rendelkezésre állását és ellenálló képességét nem garantálta.

b) a Kötelezett nem tett eleget az általános adatvédelmi rendelet 33. cikk (2) bekezdésének azzal, hogy az adatvédelmi incidenst nem jelentette be indokolatlan késedelem nélkül az adatkezelőknek.

2) utasítja a Kötelezettet, hogy jelen határozat megállapításairól a határozat kézhezvételétől számított harminc napon belül tájékoztassa a köznevelési intézményeket (iskolákat), mint adatkezelőket.

3) az 1) pontban foglalt jogsértések miatt a Kötelezettet a jelen határozat véglegessé válásától számított 30 napon belül

110.000.000 Ft, azaz száztízmillió forint

adatvédelmi bírság megfizetésére kötelezi.

****2****

The fine must be paid via bank transfer to the Authority's centralized revenue collection account (10032000-01040425-00000000 Centralized Collection Account IBAN: HU83 1003 2000 0104 0425 0000 0000). When transferring the amount, reference must be made to the NAIH-1245/2023 fine number.

If the Obligor fails to fulfill their obligation to pay the fine by the deadline, they are required to pay a late fee. The amount of the late fee is the statutory interest, which corresponds to the central bank base rate valid on the first day of the calendar half-year affected by the delay. The late fee must be paid to the Authority's centralized revenue collection account (10032000-01040425-00000000 Centralized Collection Account). In the event of non-payment of the fine and the late fee, the Authority will order the enforcement of the fine and the late fee.

There is no administrative remedy against this decision, but it can be challenged in an administrative lawsuit with a petition addressed to the Metropolitan Court within 30 days from the notification. The state of emergency does not affect the deadline for initiating the lawsuit. The petition must be submitted electronically to the Authority, which will forward it along with the case documents to the court. A request for a hearing must be indicated in the petition. For those not fully exempt from personal fees, the administrative lawsuit fee is 30,000 HUF, and the case is subject to the right to defer the fee. Legal representation is mandatory in proceedings before the Metropolitan Court.

****EXPLANATION****

I.

Background and Clarification of Facts

1. In this decision, under the designation Client or Obligor, the Authority refers to eKRÉTA Informatikai Zrt. for the factual elements prior to April 20, 2023, and subsequently to Educational Development Informatikai Zrt. Apart from the name change, the other data of the Obligor (headquarters, company registration number, tax number) have remained unchanged according to the stored company extract.

2. The Authority became aware on November 7, 2022, from an article published on an internet news portal – available at <https://telex.hu/tech/2022/11/07/kreta-rendszer-e-naplo-kozoktatas-adathalasz-ta-madas-adatszivargas-ekreta-informatikai-zrt> since 10:30 on November 7, 2022 – regarding an IT attack and data protection incident affecting eKRÉTA Informatikai Zrt. Following this, due to the content of the news and the fact that it had not received a data protection incident report from the Client prior to the publication, on November 8, 2022, it initiated an official inspection regarding the fulfillment of obligations by the Client under Articles 32-34 of the General Data Protection Regulation.

3. The linked article contains several statements, including the following:

4. "A phishing attack occurred a few weeks ago against the developer company of the Public Education Registration and Study System, i.e., eKRÉTA Informatikai Zrt. The attack was successful, allowing the attacker unauthorized access to the data of the administrative system used in all public education institutions – Telex learned from an independent source. We understand that all data of every student managed in KRÉTA may have been leaked, but not only to this data, but also to other databases of the company, the source codes, and the internal communications of the developers. Our information has been anonymously confirmed from within eKRÉTA Zrt.; according to our source with insight into the development, a phishing attack indeed occurred: a project manager clicked on an infected link in a scam email, and by obtaining their data, access was gained to internal databases, effectively reaching everything within the company's systems."

We understand that the incident occurred in September. Interestingly, around the same time as the phishing attack on the developer company, a notice titled “Important Information!” was published on the official information page called the KRÉTA Knowledge Base, dated September 20, which is still visible at the top of the page as of the time of writing this article, stating that “phishing applications (software) have re-emerged recently, which are being distributed by phishers via email and other channels.”

5. “KRÉTA is primarily known as an e-diary, but it has now expanded into a complete public education IT system. As can be seen on its website, it includes a total of twenty different modules and various applications, including services such as the e-diary, e-check, institutional administration system, digital collaboration space, e-administration, as well as administration related to health care, catering, management, and HR matters.”

6. Following the initiation of official oversight, the Authority decided to commence a data protection authority procedure on November 11, 2022, based on the presumed violation of Articles 32-34 of the General Data Protection Regulation, in light of further news that emerged – <https://telex.hu/tech/2022/11/09/kreta-rendszer-ekreta-zrt-adathalasz-tamadas-adatszivargas-elhallgatas-naih-vizsgalat-eljaras> and <https://telex.hu/tech/2022/11/11/kreta-adatszivargas-forraskod-ekreta-zrt-fejlesztok-elvandorlas> – as well as the data protection incident reports submitted to the Authority by the Client and various school districts.

7. Quotes from the articles, the links to which are included in the previous paragraph:

8. “Hello, eKRÉTA! Unfortunately, we have successfully hacked your ‘professional’ systems, obtaining a lot of data, including: source codes, databases, and I could go on! [...] By the way, thank you for the very important, informative Slack conversations; journalists will surely appreciate that you are falsifying for the police, etc.” This message greeted the employees on an internal communication platform of the company developing the KRÉTA public education administration system, eKRÉTA Zrt., after the company was subjected to a phishing attack: one of the project managers clicked on an infected link in a phishing email, and the attackers gained access to their systems, including the data managed by KRÉTA, as well as the developer databases and codes.

9. We know this because after our article revealing the data leak based on other sources was published, one of the hackers involved in the attack contacted us to disclose further details.

10. “According to images and text excerpts from the internal communication that reached us, the officials must have deliberated a lot on how to handle the situation. According to a chat message thread among project managers, one of them – the project manager who clicked on the suspicious link, thus the hacked project manager – noticed that someone with administrative access made a change that only four people, including him, know the password for, and since none of the four did such a thing, they did not understand what could have happened.”

11. “The situation is even worse because the messages in question came after Fori changed the student’s password,” the project manager later wrote when it began to unfold for them that they might have encountered a bigger problem. (The “Fori” refers to the aforementioned technical administrative account that the hackers accessed.) “What the hell” – replied another participant in the conversation. “And what the hell are we doing about all this now? Balázs doesn’t even want to know about it – which I understand...” – wrote the project manager, presumably referring to Szabó Balázs, the CEO of eKRÉTA Zrt., whom we also tried to contact several times before the publication of our previous article, but like the company’s central contact details, we did not receive a response from him via email, and he did not answer the phone either.”

4

12. “In another message, the project manager who fell victim to phishing wrote this somewhat later, at the end of September: ‘After our Thursday meeting, I was left with a bad feeling about whether we are acting appropriately. It was an important observation on your part that either we must tell the truth throughout or deny everything, but there is no possibility for modification along the way. I want you to

know that I really cannot lie, nor do I want to.' Regarding the account with administrative rights, which was discovered to have been accessed by someone, they wrote: '[...] we can admit that we had such a technical user, but we immediately terminated it after the incident, which is completely true. (This came to light on Sunday, September 18; I immediately changed the password, and then the next day I deleted all user logins – I set them to deleted.) [...] If we were to deny this, and they had evidence (picture, video, login data downloaded from me, anything), then we would find ourselves in a situation that we must avoid at all costs.' The full text of this last letter, along with some images, was already published by the hackers on Monday evening on the Telegram channel where, according to our informant, they plan to publish further data."

13. "We also asked the hacker how they managed to gain access to the eKRÉTA systems. According to their claim, they managed to introduce a malware program they wrote, a so-called RAT (remote access trojan), in such a way that it passed unnoticed through all of the company's antivirus and security software. This type of malware is precisely good for what its name suggests: it installs on the infected system and thus allows the attackers to gain access: it enables remote access, which can mean remote monitoring of the system, but also running commands or extracting data."

14. The trojan was spread through the KRÉTA messaging system: they selected every administrator and sent a deceptive phishing email, posing as someone else, containing the link necessary for downloading the malware, disguised as something that could pique the interest of the targeted administrators – as we have seen since, it indeed caught the interest of one of them. One project manager clicked before employees were informed within the company that there were phishing emails, and thus they managed to obtain their password, which allowed them access to everything. "There was no two-factor authentication, and everything runs on one system, so if you have access to owa.rufusz.hu, then you have access to everything," said the hacker. (Rufusz Computer Informatika Zrt. is one of the companies owned by Zoltán Fauszt, whose interests also include eKRÉTA Zrt. – we wrote about this at the end of our previous article.)

15. In mid-September, they did not yet have access to the systems; they only gained entry into the aforementioned technical administrator account, which operated in every school, but even with this, they could view any student's address and other data. "Later we realized that we actually had access to everything: emails, source codes, etc." According to the hacker, they ultimately extracted 238 GB of data from the company in compressed form. They do not know the exact number of individuals affected by their personal data, but it could be several tens of thousands."

16. "We understand that at eKRÉTA Zrt. in September, after they became aware of the hackers' entry, they even reached the conclusion that no data breach had occurred (they certainly did not know that the hackers were still in their systems more than a month later). The traces of data exfiltration were only discovered after our first article, but they believed that the attackers' access was more limited. They thought they could only access what was available on the machine of the project manager who was deceived by the phishing email for various reasons, not the entire system – which, if proven, would be good news, as it would mean that the circle of practically affected individuals would be much narrower than theoretically possible. Unfortunately, we still cannot confirm any of this from official sources, as the company..."

5

"to any of our inquiries through any channel before the publication of our articles to clarify the events."

17. In its data breach notification dated November 10, 2022, the Client shared the following information with the Authority.

18. The Client became aware of the attack on November 7, 2022, through a post published by the attacker on the channel used for the Client's internal communication, indicating the presence of the attacker. Based on the published post, the attacker gained access to the Client's internal development environments, channels used for work organization and execution, and monitored them.

19. The attacker sent a message containing a malicious code link to employees of several educational

institutions via the KRÉTA system, and one of the Client's employees clicked on the link contained therein. This allowed the attacker to enter and remain in the affected colleague's computer for an extended period, through which they could access the systems used for work at the Client, including passwords stored on the computer. The incident may have affected approximately 1,300,000 personal data records, belonging to around 100,000-150,000 users (who may include employees, students, and parents with user permissions).

20. Regarding the notification of the affected individuals, the Client stated in the report that they have informed the individuals or plan to inform them as deemed necessary depending on the investigations.

21. After detecting the incident, the user's computer was reinstalled, and the affected user account was terminated. The process of enhancing the security of services within the network was underway (tightening remote access, MFA, reviewing necessary and sufficient permissions, IT security sensitization, training).

22. During the authority's procedure, on November 17, 2022, the Authority's staff conducted an on-site inspection at the location agreed upon with the Client, at the Client's central administrative office (1117 Budapest, Gábor Dénes utca 4.) with prior notice. Before the inspection, the Client informed the Authority that regarding the live KRÉTA system, the IT infrastructure elements for public educational institutions maintained by the Klebelsberg Center are located at NISZ National Infocommunication Service Provider Ltd. The Rufusz Computer Informatics Service Provider Ltd. (headquarters: 1111 Budapest, Budafoki út 59., company registration number: 01-10-140532) performs data processing activities for the Client's internal development environments, work organization, and internal channels used for work. During the on-site inspection, the Client provided the following information in response to questions posed by the Authority.

23. The Client is also engaged in software development and providing expert services. As soon as they detected the incident [note: in mid-September 2022], they immediately replaced the computer of the employee who fell victim to the phishing attack (hereinafter: affected user) and deactivated their permissions, but the employee had synchronized their login data to their Google account. According to their statement, they did not synchronize the authentications necessary for NISZ access there. A session remained open towards Google for the attackers, allowing them to obtain the password. The incident occurred within the corporate network, not in the live KRÉTA system. The affected user did not have administrative privileges. The Client provided the Authority with a record of the IT security and other measures taken following the incident and stated that they would provide the Authority with log files regarding employee access permissions. 600 of their colleagues have VPN access rights due to the COVID pandemic.

24. The affected user had access to the email system, an internal communication-supporting chat system, the IT development system containing the source codes of the KRÉTA system, and the support system.

6

accessed personal data in the KRÉTA system on a permanent basis, as well as temporarily in connection with the performance of support tasks.

25. According to the Client's statement, they had no information regarding any personal data being leaked, as the KRÉTA system operates in a protected state environment. Those who log in legitimately do not undergo any further internal filtering. They did not detect any significant data flow through the VPN.

26. In the incident that occurred in September 2022, there was no significant data movement over the VPN, and therefore the Client closed the case. Subsequently, in November 2022, a message appeared on the internal communication platform from the attackers stating that they had hacked their system. At that point, the Client realized that the problem was larger than they had believed, and they made the necessary reports and examined the environments where the developers were working. This involved Excel spreadsheets that contained personal data saved from the live KRÉTA system. These

were with the Client because the affected user was performing support activities and various bug-fixing tasks related to the KRÉTA system, as well as handling inquiries, which may require transferring data from the live system. Inquiries arrive at the Client via the [...] system or through email, and it frequently occurs in the error reporting messages that personal data is included. The Client regularly deletes these files containing personal data and does not keep a record of what personal data has been transferred to their system in this way, but this constitutes less than 1% of all personal data stored in the live system.

27. The attacker entered with valid credentials, therefore the Client cannot track the logs of internal activities and cannot provide them. According to the Client's statement, it cannot be ruled out that the affected user's VPN access was used to access the live system. In principle, it is conceivable that they gained access to the live system managed by NISZ Zrt. via the VPN, but this has not been confirmed by any investigation either at NISZ Zrt. or at the Client.

28. During the support activities between September 10, 2022, and November 9, 2022, the data saved from the live system affected 10 institutions (approximately 1.3 million personal data). In response to the Authority's inquiry, the Client stated that the 1.3 million personal data is only an estimate, and they have no knowledge of exactly whose and what type of personal data these are.

29. The Client's IT expert could not confirm the information reported in the press that 238GB of data had been copied from the system, stating that this could be determined from the logs.

30. Notification of the September incident came from the institutions, and the Client was requested to conduct an investigation. As data controllers, they requested the assistance of the data processor regarding their own incident, and therefore the Client did not see the need to make a report at that time.

31. The Client had previously attempted to change the password policy for users, but this did not receive support from the Klebelsberg Center. In the case of the November detection, an internal investigation was conducted on November 8, 2022, and the information was posted on the user side of the KRÉTA system on November 10, 2022. A message confirming the fact of the attack was sent to all institution leaders, stating that they had not accessed the live system. The text of the notification was attached by the Client to the data protection incident report submitted to the Authority. During the support activities, the individuals and data controllers of the personal data saved in the Client's internal systems were not separately notified about the incident; only the above notification was communicated to them.

7

32. Access to the KRÉTA system was enabled with two-factor authentication only on November 10.

33. The source code of three modules was leaked, which represents 20% of the total source code. By the time of the on-site inspection, the leaked source code had already been modified, with approximately 90% similarity. The Client did not notice the extraction of the source code.

34. There was no indication that the attacker had access to the Client's systems at the time of the on-site inspection conducted by the Authority. Foreign IP addresses were blocked, and the Client's colleagues have been continuously monitoring these activities since then.

35. At the end of the inspection, the Client's representatives handed over to the Authority the VPN traffic data of the affected user for the period from September 14, 2022, to November 8, 2022, as well as the following commitments from the Client to be fulfilled by RUFUSZ Zrt.:

- Submission of the rights matrix to the Authority regarding the affected user by November 22, 2022,
- Submission of the VPN data of the affected user for the period between November 8-17, 2022, to the Authority,
- Provision of presumably relevant filtered user logs.

36. On November 30, 2022, the Client sent its responses to the questions previously posed in writing by the Authority, which were summarized as follows.

37. Regarding the KRÉTA system, the Client acts solely as a data processor, with the following educational institutions (schools) considered as data controllers:

- In the case of parent/child users, the institution where the child is a student
- In the case of educators/other employed persons, the institution employing them.

38. The educational institutions collect personal data from the data subjects, and they determine the purpose, method, and means of processing the data recorded about students/guardians/employees in accordance with the relevant provisions of Act CXC of 2011 on national public education. The Client is considered a data processor in relation to the KRÉTA system based on the Software Product Service Agreement (or contract) related to the KRÉTA system concluded with the institutions or their maintainers that use the KRÉTA system, as well as the associated data processing agreement.

39. Based on the contracts, the Client provides KRÉTA product support services, which include the following:

- Customer service – Operation of Helpdesk
- System monitoring, compliance with legal regulations
- Handling of reports (commences troubleshooting after the report of errors related to the KRÉTA System)
- Performing software updates
- Expert and consulting activities
- KIR interface support
- Conducting training
- Supporting KRÉTA information security and data protection audits
- Preparing monthly deliverables (report on KRÉTA product support; report on KRÉTA software updates; report on KRÉTA product support (reports) regarding the affected modules)

8

The Client also ensures the provision of data services to authorities and institutions under the contract.

40. According to the Client, the articles linked at the beginning of the decision do not fully reflect the actual events. Based on their investigations, the phishing attack did not affect the live KRÉTA system, but only the tools used by the Client for internal work and organization. On September 15, 2022, several institutions contacted the Client, reporting that employees of those institutions received messages containing malicious code via a link through the KRÉTA system. The malicious code was forwarded to the Client's colleagues involved in the investigation via the Outlook email system for examination. At that time, the affected user clicked on the link to investigate it. On September 18, 2022 (Sunday), the affected user received a notification of suspicious activity (login) through their Gmail account and changed their password at that time. The payroll program also sent an email to the workplace email address, requesting confirmation of the login with a code related to two-factor authentication. On September 19, 2022, the affected user reported the issue to their supervisor and the operations group leader, also informing them that they had previously clicked on the link containing the malicious code. The Client's colleagues in operations – after running the link containing the malicious code in an isolated environment – instructed employees on September 21, 2022, at 15:20, to immediately check their computers and verify whether a specific folder had been installed on their computers. The affected user found the mentioned folder on their computer, while in another employee's case, this folder was not installed on the computer. Concurrently with the detection of the incident, the Client's CEO was also informed about the events and the proposed immediate measures. The affected user's login credentials and permissions were immediately deactivated around 16:00 on September 21, 2022, after the folder was detected, and their machine was removed from the network. On the same day, the affected user brought their computer to Rufusz Computer Informatikai Zrt., received a new computer, and a new password as well. Subsequently, they gradually regained access to the VPN and other passwords. On September 22, 2022, the affected user set up the new computer and password on the Client's network (as an internal network connection is required for the first login). Under the supervision of the operations group leader, they changed all previously used passwords. The designated colleagues of the Client investigated each report and analyzed the log data related to

the login to take the necessary measures. On September 23, 2023, requests from foreign IP addresses were restricted on all incoming traffic in the live environment, and NISZ Zrt. was also requested to take action to block foreign IP addresses. On September 23, 2022, the Client contacted the National Cyber Defense Institute of the National Security Service and took the steps they recommended (password change, examination of machines).

41. Since the attacker remained in the internal systems using the Client employee's username and password – without any modifications or activity – the Client only became aware of the ongoing nature of the attack and the possibility of the incident occurring on November 7, 2022, when a message from the attacker appeared on the internal communication platform stating that the Client's internal systems may have been hacked. Following this awareness, the Client requested the assistance of experts on the same day regarding which systems were affected or could have been affected by the attack. Conducting a detailed investigation took a longer time. A report on the course of the investigation and its results was sent to the Authority. After the investigations, on November 10, 2022, the Client began the process of reporting the data protection incident to the Authority.

42. According to the Client, the data protection incident was caused by the attacker's unauthorized access to the Client's internal systems and the data contained therein. The risk assessment related to the incident was also sent to the Authority.

9

The Client provided part of the relevant log files to the Authority's staff during the on-site inspection conducted by the Authority, while the additional log data and relevant permissions were sent to the Authority as an attachment to the response letter.

43. In accordance with the communication protocol established under the contract for the support of the software product, the Client notified the data controllers with the following system message (placed on the main screen of the institutions' KRÉTA accounts) on November 10, 2022: "Dear Recipients! eKRÉTA Informatikai Zrt. has reported the suspicion of an incident related to an attack affecting the Company's internal development environments and internal channels used for work organization and performance, in connection with the articles published on internet news portals, to the National Authority for Data Protection and Freedom of Information in accordance with the laws. Our company is currently conducting an investigation regarding the identification of potentially affected systems and data."

44. In response to the questions posed by the Authority in its letter dated December 19, 2022, with reference number NAIH-8516-10/2022, the Client provided the following answers.

45. The previously saved personal data from the KRÉTA system (which were accessible on the affected user's computer at the time of the attack for testing purposes), the number of affected individuals, and information regarding the quantity of data were included in the Excel spreadsheet sent as an attachment to the response, which contains personal data related to 12 vocational training centers (as mentioned in paragraphs 59-60 of this decision), totaling – according to the data in the Excel spreadsheet – 8574 students ~290,000 data points, 11,082 guardians ~44,000 data points, and 1205 employees ~35,000 data points.

46. Regarding the Client's internal systems, the affected individuals are the Client's employees who have access to the affected internal communication system. Only the employees' names (full name or fictitious username) used to log into the internal messaging system became accessible to unauthorized persons. Regarding the quantity and categories of personal data that may have become accessible in other internal systems, the Client responded to the Authority's inquiry on December 8, 2023, as follows. In November 2022, the Client had 138 employees, of which 36 belonged to the KRÉTA Project Directorate as an organizational unit, where the affected user also belonged based on their job role. At the time of the attack, the affected user was logged into the following systems: [...], [...], [...] (password storage), Notepad++, VPN, Total Commander, Office 365 and Outlook, Slack (internal communication platform), web browsers, administration, [...] (leave management application). Access to all systems, except for Slack and [...], was possible through authentication used for logging into the company

account; access to the Slack application required a work email address and personal password, while access to [...] was possible with a username and password. On the Slack messaging system, colleagues can see each other's names as personal data, thus the attacker could see the names of logged-in employees on this platform. Employees sometimes share (work-related) personal photos on this platform, resulting in the attacker downloading a photo of one colleague from the messaging system and publishing it on the Telegram channel (where the KRÉTA source code was also published). The Outlook email system is used by all employees of the Client, containing the names, positions, and contact information (email address, phone number) of the employees. The attacker could have become aware of the correspondence data of those with whom the affected user had communicated in the preceding period. In the [...] system, the names of the employees are also visible, as well as whether the employee is on leave. In the case of [...], the attacker could have accessed un-anonymized test data from the KRÉTA system (see paragraph 45). The Client mentioned that during the investigation of the incident, the focus was primarily on examining any incidents affecting the KRÉTA system before investigating the internal systems, which resulted in the determination that the KRÉTA

10

The system has not been subjected to a phishing attack. An external state-owned contractor is conducting an investigation for the Client until the end of December 2023, during which a search aimed at uncovering data related to users of the KRÉTA system will be carried out on the so-called dark web.

47. In order to clarify the facts appropriately, the Authority has contacted NISZ Zrt. multiple times, from which the following information has emerged.

48. NISZ Zrt. provides only certain infrastructure (IaaS) and firewall services to the Klebelsberg Center, as the client, concerning the KRÉTA system; the operation of the operating systems running under KRÉTA and the KRÉTA application falls outside this service scope. Regarding the firewall, NISZ Zrt. only makes configurations based on the Client's request, considering that it provides services only up to the transport layer according to the OSI model (up to layer 4). In this context, the activities of NISZ Zrt. are limited to: allowing or blocking IP addresses and ports between the source and the destination.

49. Based on the above, NISZ Zrt. is not in a position to comment on either the accesses to the application or data, nor their legitimacy or illegitimacy, because these activities occur at the application level (application layer, layer 7). NISZ Zrt. does not monitor or log events above the network (layer 3-4) level within the scope of the services provided.

50. NISZ Zrt. was not contacted by eKRÉTA Zrt. regarding the data protection incident that occurred with them; NISZ Zrt. learned about it from the press. On September 22, 2022, at 14:43, the Klebelsberg Center requested the "temporary blocking of foreign access to the KRÉTA system" via email to the NISZ Customer Service. The justification for this request was as follows: "Unfortunately, the number of attacks against the KRÉTA system has increased in recent days. The attacks occur using various methods, but their common feature is that the attempts are almost exclusively from foreign IP addresses."

51. Additionally, NISZ Zrt. received the following request from the Client on September 26, 2022: "Please review the settings made, as there was a successful attempt from the [...] IP address at 2022-09-24 10:21:25.727!"

52. NISZ Zrt. is not aware of whether the above firewall configuration requests related to the live system are connected to the data protection incident reported in the press.

53. The border protection system (firewall) of NISZ Zrt. does not perform user identification (authentication) and authorization, thus it cannot investigate unauthorized access. NISZ Zrt. has not conducted an investigation regarding unauthorized access on its own initiative.

54. Due to the level of operational services related to the KRÉTA system (IaaS), NISZ Zrt. is not competent to answer the question of whether it can be completely ruled out that the attacker(s) gained

access to the live KRÉTA system and extracted data from it.

1 The dark web is a part of the internet that remains hidden from traditional search engines; it is a specific part of the deep web (deep web) where anonymity and encryption play a significant role. Activities occurring here can include communications for legal and legitimate purposes, but illegal activities such as drug trafficking, arms trading, preparations for cyberattacks, and other illegal services are also common. It is referred to as the "dark" web because its hidden nature and anonymity make it difficult to trace.

11

55. In a letter received by the Authority on March 8, 2023, the Client provided the following information.

56. The Client accesses the live KRÉTA system at NISZ Zrt. through a [...] VPN connection in the established VPN tunnel (which is an encrypted connection between the device and the VPN server). This is unbreakable without an encryption key, so neither attackers nor the internet service provider (ISP) can access the data. The VPN tunnel essentially represents a private route through the intermediaries to the internet, with no protocol or port-level restrictions. On the receiving end, the establishment of the VPN connection occurs solely over an encrypted SSL channel. The VPN is a standard [...] VPN. The Client's source address is: [...]. The target IP addresses of the live KRÉTA system are: [...] and [...].

57. In the VPN system used for the Client's development environment, foreign IP address ranges were also blocked as of November 9, 2022.

58. From the available log files, it can only be established that the affected user logged into the live KRÉTA system using their identifier and password exclusively through the systems regularly used by the Client; it cannot be determined retrospectively whether there was any unauthorized login among them.

59. The Client does not have user-level access to the KRÉTA system, but through the VPN connection, the Client has access to the databases, logging systems, and application servers running behind the KRÉTA system for the purposes detailed in the cooperation agreement - solely with named users and with necessary and sufficient permissions. Thus, the Client has access to all data stored in the KRÉTA system, in addition to the passwords stored in the KRÉTA system, which are:

12

13

61. According to the Client's information, the live KRÉTA system contains personal data of approximately 225 thousand employees, one and a half million students, and 1.87 million guardians. In terms of the quantity of personal data, this means approximately 6.5 million records for employees, approximately 47 million for students, and approximately 7.5 million for guardians (the completeness of the data continuously changes based on the data entry habits of users and institutions, as well as enrollments and withdrawals). Users do not always record data for the data categories appearing in the KRÉTA system if filling in the given field is not mandatory.

14

□□□

62. During the proceedings, the Authority thoroughly examined whether the IP address mentioned in paragraph 51 could be linked to the case at hand. In this context, NISZ Zrt. sent a table to the Authority as an attachment to its letter received on May 16, 2023, which contained the filtered log entries for the examination period indicated by the Authority (September 15, 2022 – November 7, 2022), where the source IP address was as mentioned in paragraph 51. Based on the available traffic data, NISZ Zrt. could not determine what access occurred to the live KRÉTA system server. The operational tasks are carried out through remote access via a protected channel specifically designed and maintained for these tasks, and there were no regulatory changes regarding this during the examined period.

63. In this regard, the Authority's IT experts prepared an expert opinion on June 5, 2023, which included, among other things, the following findings:

64. Regarding the hacking of the KRÉTA system, it can be established based on the responses received from NISZ Zrt. to the Authority's questions on May 16, 2023, and the log files submitted as evidence, that the logs are incomplete. NISZ Zrt. refers to a technical error, which is why a significant portion of the logs is missing. The questions also pertained to the attacking IP address mentioned in NISZ Zrt.'s previous correspondence with the Client, where we can be certain (based on the email sent by the Client to NISZ) that unauthorized access occurred from that IP address. The mentioned "attacking" IP address: [...]

65. [...]

66. The logs received from NISZ Zrt. did contain the date specified in the correspondence, although this log file was also incomplete. From the log files, the Authority's IT experts extracted that the attackers accessed two other IP addresses through the attacking IP address: [...] and [...].

67. At the time communicated by the Client in the email, the attacking IP address accessed the [...] IP address. Both IP addresses were accessed through port 443, that is, via the HTTPS protocol, as can be seen from the log. This port, established as a standard by IANA and widely used as a standard, is used in IT for encrypted communication between the client and server, realized with the so-called SSL certificate. It is not customary to expose a test system containing live data to a public network, as this does not comply with best industry practices; such test systems operate on a closed/protected internal network, and remote access should be ensured through a protected channel. Examining the aforementioned IP addresses, it appears that the attackers could also access the live system. The IP address ending in [...] belongs to the publicly accessible live KRÉTA system. Both IP addresses accessed by the attacker lead to the authentication interface of the live KRÉTA system, where users can initiate electronic administration after entering their login credentials.

68. The IT expert opinion was sent to the Client for informational purposes, who responded to the contents as follows.

69. In September 2022, several inquiries were received from the police regarding the initiation of an investigation against an unknown perpetrator for the crime of threatening public safety. The perpetrator(s) accessed the accounts of certain users of the KRÉTA system using valid user data, followed by the sending of a message containing malicious code, which several users clicked on. At that time, the Client investigated the events at the request of the institutions and the police, and during the investigation, it was established that the unauthorized logins mostly occurred from foreign IP addresses. For this reason, the Client's staff took measures to prevent further attacks.

15

Actions were taken to block foreign IP addresses. The colleagues of NISZ Zrt. were also informed about this setting, and it was initiated that NISZ Zrt. should also take the necessary measures to block foreign IP addresses. Regarding the [...] IP address, the Client's employees again detected access attempts and login attempts, therefore they requested NISZ Zrt. to check the settings related to foreign IP addresses once more.

70. In connection with the letter mentioned in paragraph 51, the Client noted that in this case unauthorized password usage occurred, meaning that the "attacker" obtained the user's username and valid password, thus gaining access. The IP addresses listed in the expert opinion are the public IP addresses of the KRÉTA system [...], which can be accessed by anyone, and with a valid username and valid password, one can log into the respective KRÉTA system. The expert's conclusion regarding the two IP addresses above is correct, stating that "upon examining the aforementioned IPs, it appears that the attackers could also access the live system."

71. Every user accesses the KRÉTA systems through these IP addresses with a valid username and password. The Client emphasized that these IP addresses, and the letter mentioned in paragraph 51, also pertain to the live public KRÉTA system.

72. The Client also agreed with the expert's conclusion that "both IP addresses accessed by the attacker lead to the authentication interface of the live KRÉTA system, where users can initiate electronic administration after providing their login details."

73. Based on the above, the Authority was unable to establish a definitive connection during the proceedings between the attack conducted from the [...] IP address and the data protection incident in question, as well as the attack that caused it; therefore, the circumstances uncovered in this regard were not taken into account during the imposition of sanctions.

□□□

74. In the response sent by the Client on October 30, 2023, regarding the logging conducted by them, it was stated that in the KRÉTA system, logging is done at the application level rather than by roles. Each log entry records the following data in the case of the respective events: 1) creation of a record (who and when created the respective record), 2) modification of a record (who and when modified the record, both the original and modified values are stored), 3) deletion of a record (who and when deleted the record).

75. The Client's employees have the following access to the log entries: 1) operations / ITB responsible (access level: full), 2) product support (access level: read rights), 3) developers (access level: read rights), 4) developers when using CI/CD tools (deployment) (access level: full, during deployment/modification).

76. In response to the Authority's inquiry, the Client also informed the Authority about the measures taken as a result of the incident. These were as follows:

2 CI/CD is a methodology in software development that combines Continuous Integration (CI) and Continuous Delivery (CD). Continuous Integration is a development practice where developers integrate code into a shared repository several times a day, coordinating so that even small changes become quickly available to the rest of the team. After integration, every new piece of code is checked, allowing developers to identify problems early and fix them at the outset, thus saving time and minimizing the amount of code that needs to be corrected. The goal of Continuous Delivery is to receive feedback on the work as soon as possible so that it can be better aligned with the client's needs.

16

a) Review of authentication solutions, overview of regulations: This took place in November-December 2022.

b) Review of email security: An informational notice regarding phishing activities was placed on the central KRÉTA page, and the Client's employees received separate information on this topic concerning internal systems and their own emails. A document titled "Secure Password Storage in Browsers" and a general guide for recognizing phishing emails were also sent to the employees.

c) Foreign IP addresses have been blocked from accessing the KRÉTA systems' web interfaces, as well as the Client's VPN access (exception lists can be authorized based on individual requests).

d) In November 2022, instructions were issued to enhance the security of usernames and passwords belonging to the Client's internal network. This includes a prohibition on saving passwords associated with the company's systems (Outlook, [...], [...], KRÉTA in PROD or UAT environments, and other KRÉTA modules, etc.) in the browser. Different passwords must be used for systems that do not utilize AD authentication. Passwords must exceed AD policy requirements and be non-guessable. Sharing passwords with anyone is prohibited. Private and company passwords must be strictly separated.

e) Implementation of two-factor authentication on November 15, 2022: for access to the Klebersberg Center VPN, the Slack application used for the Client's internal communication, and for [...]. The Client has introduced mandatory two-factor authentication for employees' access to internal systems and has prohibited the private use of personal Google accounts on workplace devices.

f) On June 9, 2023, the Client published a new, revised IT security policy based on international best practices.

- g) The transformation of network resources took place in February 2023.
- h) The Client's employees underwent data security and data protection training in January 2023.
- i) The possibility of column-level encryption for databases has been assessed; however, due to concerns about system performance degradation, its implementation is currently not feasible.
- j) All case backups (copyonly) or backup chain files created after October 31, 2023, will be stored in encrypted form. Restoration of these can only occur with possession of the encryption key.
- k) Implementation of multi-factor authentication: The document titled "Establishment of New Password Management Procedures" has been completed, and the function is under development. Its purpose is to enhance security in the registration and login processes for students / teachers / institutional administrators / central KRÉTA users and guardians. This function was introduced for central KRÉTA users / teachers / institutional administrators in June 2023.
- l) The Client's database security policy (access management, principle of least privilege, separation of roles) has been completed, and its announcement was in progress at the time of response.
- m) The highest-level access rights in the Client's network were reviewed in January 2023.
- n) The institutional KRÉTA SQL server located within the NSZFH (National Office for Vocational Education and Adult Training) environment has been inspected.
- o) Orientation for all employees on October 26, 2023, to use only Windows or certificate-based authentication.
- p) An assessment was conducted regarding the software and hardware requirements for key storage, with implementation planned by the end of 2023.
- q) The Client has performed interim key changes compared to regular API key exchanges.
- r) Password changes for non-personalized users required for automated processes at the system level:

There are fundamentally three such entities in the KRÉTA system:

1. [...]

17

2. [...]

3. [...]

The exchange of all three took place between November 7 and November 15, 2022.

s) The security review of the codes used in the development environment has been completed. Preconditions have been established to ensure that the automated review occurs continuously. Developers can only log in as named users. Continuous review and the appropriate connection mode setup are in place for all projects where necessary.

II. Applicable Legal Provisions

77. According to Section 99 of Act CL of 2016 on General Administrative Procedure (hereinafter: Ákr.), the authority – within the limits of its competence – monitors compliance with the provisions laid down in the law, as well as the fulfillment of what is stated in the enforceable decision.

78. According to Article 2(1) of the General Data Protection Regulation, the General Data Protection Regulation must be applied to data processing affected by a data protection incident.

79. Article 4(12) of the General Data Protection Regulation defines what constitutes a data protection incident, stating that a “data protection incident” is a security breach that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

80. According to Recitals (75) and (76) of the General Data Protection Regulation, risks affecting the rights and freedoms of natural persons may arise from the processing of personal data, which can lead to physical, material, or non-material damage, particularly if the data processing results in discrimination, identity theft or misuse of identity, financial loss, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social disadvantage; or if data subjects cannot exercise their rights and freedoms, or cannot have control over their personal data; or if the processing

involves personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as if the processed data concern genetic data, health data, or data related to sexual life, criminal liability, or related security measures; or if there is an assessment of personal characteristics, particularly concerning workplace performance, economic situation, health status, personal preferences or interests, reliability or behavior, location or movement for the purpose of creating or using a personal profile; or if the processing of personal data of vulnerable individuals – especially children – takes place; or if the data processing is based on a large volume of personal data and affects a large number of data subjects. The probability and severity of the risk to the rights and freedoms of data subjects must be determined based on the nature, scope, circumstances, and purposes of the data processing.

81. According to Article 32(1) of the General Data Protection Regulation, the data controller and the data processor shall implement appropriate technical and organizational measures, taking into account the state of science and technology and the costs of implementation, as well as the nature, scope, circumstances, and purposes of the data processing, and the risks to the rights and freedoms of natural persons, which are variable in probability and severity, in order to mitigate the risk.

18

guarantees an appropriate level of data security, including, among other things, (a) ensuring the continuous confidentiality, integrity, availability, and resilience of the systems and services used for the processing of personal data, as specified in point (b).

82. According to Article 32(2) of the General Data Protection Regulation, when determining the appropriate level of security, account must be taken of the risks arising from the processing of personal data, particularly the accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

83. According to Articles 33(1) and (2) of the General Data Protection Regulation, the data controller must notify the competent supervisory authority referred to in Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of a personal data breach, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification is not made within 72 hours, reasons for the delay must be provided. The data processor must notify the data controller of the personal data breach without undue delay after becoming aware of it.

84. According to Article 34(1) of the General Data Protection Regulation, if the personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller must inform the data subject of the personal data breach without undue delay.

85. According to Section 2(2) of Act CXII of 2011 on the Right to Informational Self-Determination and on Freedom of Information (hereinafter: Infotv.), the General Data Protection Regulation must be applied with the supplements specified therein.

86. According to Section 101(1)(a) of the Administrative Procedure Act (Ákr.), if the authority detects a violation during an official inspection, it shall initiate its official procedure. Based on Section 38(3) and Section 60(1) of the Infotv., the Authority shall conduct an official data protection authority procedure ex officio in order to enforce the right to the protection of personal data as specified in Section 38(2) and (2a) of the Infotv.

87. According to Section 60(3)(b) of the Infotv., the Authority shall initiate an ex officio data protection authority procedure if it finds, based on its investigation, that a violation of the processing of personal data has occurred or there is a direct risk of such a violation, and that a fine is warranted under the provisions of the General Data Protection Regulation.

88. According to Section 103(1) of the Ákr., the provisions of the Ákr. regarding procedures initiated upon request shall be applied with the deviations specified in Sections 103 and 104 of the Ákr.

89. According to Section 60/A(1) of the Infotv., the administrative deadline in the data protection

authority procedure is one hundred and fifty days, which does not include the time from the call for the provision of data necessary for clarifying the facts until its fulfillment.

90. In the present procedure, the clarification of the facts between the Authority and the Client took place between the following dates: November 14, 2022, and November 30, 2022; December 19, 2022, and January 16, 2023; February 16, 2023, and March 8, 2023; June 12, 2023, and June 23, 2023; October 13, 2023, and October 30, 2023; October 26, 2023, and November 7, 2023; as well as November 23, 2023, and December 8, 2023. The clarification of the facts between the Authority and NISZ Zrt. took place between the following dates: December 19, 2022, and January 19

16. days, February 16, 2023, and March 3, 2023, as well as March 17, 2023, and May 16, 2023.

91. According to Section 103 (4) of the Administrative Procedure Act (Ákr.), if the authority exceeds twice the administrative deadline in an official procedure, it may not apply any other legal consequences beyond establishing the fact of the violation and ordering the cessation of the unlawful conduct or the restoration of the lawful state. In this case, no new procedure may be initiated against the same client on the same factual and legal basis.

92. Based on point a) of Section 61 (1) of the Information Act (Infotv.), the Authority may apply the legal consequences specified in the General Data Protection Regulation (GDPR) in connection with the data processing operations defined in Section 2 (2) and (4).

93. According to points b) and i) of Article 58 (2) of the GDPR, the supervisory authority shall take corrective action against the data controller or data processor if their data processing activities violate the provisions of the regulation, and may impose an administrative fine in accordance with Article 83, depending on the circumstances of the case, in addition to or instead of the measures mentioned in this paragraph. Pursuant to point d) of the same paragraph (2), the supervisory authority shall instruct the data controller or data processor to bring their data processing operations into compliance with the provisions of the regulation—if applicable, in a specified manner and within a specified time frame.

94. The conditions for imposing an administrative fine are contained in Article 83 of the GDPR. In the event of a violation of Articles 32-33 of the GDPR, the upper limit of the fine that may be imposed is, according to point a) of Article 83 (4), €10,000,000 (EUR) or, in the case of enterprises, an amount not exceeding 2% of the total annual worldwide turnover of the preceding financial year.

95. The provisions of Sections 80 and 81 of the Ákr. shall apply to the decision in other respects.

III. Decision

Findings related to data security

96. The Authority specifically examined during the procedure to what extent the Obligor complied with the data security requirements directly related to the occurrence of the incident concerning its own development environment, system, and access to the live and test databases of the KRÉTA system from there. The procedure did not address what data security settings are applied during access to the live, public KRÉTA system by students, parents, and teachers.

97. According to Article 32 (1) of the GDPR, the data controller must implement technical and organizational measures appropriate to the level of risk to guarantee a level of data security that is in line with the state of science and technology, including ensuring the ongoing confidentiality, integrity, availability, and resilience of the systems and services used for processing personal data as per point b) of Article 32 (1) of the regulation.

98. In determining the appropriate level of security according to Article 32 (2) of the GDPR, specific consideration must be given to the risks arising from data processing, particularly those related to the transmission, storage, or otherwise handling of personal data.

20

arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or

unauthorized access to them.

99. According to Article 28(1) and (3) of the General Data Protection Regulation, if the processing of data is carried out by another entity on behalf of the data controller, the data controller may only engage data processors who provide sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation and the protection of the rights of data subjects. The data processing carried out by the data processor must be governed by a contract or other legal act established under EU law or the law of a Member State, which defines the subject matter, duration, nature, and purpose of the processing, the types of personal data, the categories of data subjects, as well as the obligations and rights of the data controller, binding the data processor to the data controller. The contract or other legal act must particularly stipulate that the data processor: [...] c) implements the measures specified in Article 32; [...].

100. As seen in the above paragraph, the General Data Protection Regulation does not differentiate between data controllers and data processors concerning compliance with data security requirements; the referenced provisions apply equally to data processors as they do to data controllers.

101. The evaluation by the Authority of the data security settings applied by the Obligor and the incident management measures of the Obligor is crucial, as the KRÉTA system's live and test databases, to which the affected user also had access, contain the personal data of all students, educators, and guardians (see the tables in paragraphs 59-60). Among these, there are several pieces of information whose disclosure could particularly adversely affect the data subject, e.g., whether the student is struggling with integration, learning, behavioral, or educational difficulties; whether they have special educational needs; whether they are state care recipients; whether they receive social support or regular child protection benefits. Although not a mandatory element, the student's religion may also appear in the KRÉTA system. Furthermore, in the KRÉTA system, personal data is stored in large quantities and extends to a significant number of data subjects: approximately 225,000 employees, 1.5 million students, and 1.87 million guardians' personal data can be found in the system. In terms of the quantity of personal data, this amounts to approximately 6.5 million for employees, approximately 47 million for students, and approximately 7.5 million for guardians. Therefore, it is of immense importance how the Obligor's staff, as developers, access the development environment and the live and test system databases, as they can reach them at the service level.

102. Based on the established facts, the affected user also performed support activities, and consequently had all the necessary permissions to access the live and test KRÉTA systems and their databases. The Obligor informed the Authority that the affected user had permanent access to the email system, an internal communication-supporting chat system, a separate system storing the source codes of the system, and the support system, and temporarily accessed personal data in the live KRÉTA system in connection with performing support tasks.

103. The Obligor also stated during the proceedings that it often happens that live data is worked with, and numerous live records were found on the affected user's machine, which were downloaded from the live system during support activities. Regarding the number and quantity of personal data previously saved from the KRÉTA system for testing purposes, which were available on the affected user's machine at the time of the attack, the Obligor stated that personal data related to 12 vocational training centers is included, in total – the Obligor.

21

According to the data included in the Excel spreadsheet sent to the Authority – 8574 students ~290,000 data entries, 11,082 guardians ~44,000 data entries, and 1205 employees ~35,000 data entries.

104. Since the Obligor provided the Authority with the log files of accesses made with the affected user's user ID during the relevant period (September 14, 2022 - November 8, 2022) during the on-site inspection, and these contained the target IP addresses of the live KRÉTA system, it can be clearly established that the affected user had access to and did access the live KRÉTA servers. Moreover, the

Obligor had the necessary permissions, as the Obligor also stated in its response – although it does not have user-level access to the KRÉTA system, it does have access to the databases, logging systems, and application servers running behind the KRÉTA system via VPN for the purposes detailed in the cooperation agreement – exclusively with named users and with necessary and sufficient permissions. The Excel spreadsheets sent by the Obligor, which contain the permissions of the affected user, confirm that the affected user had editing rights to access the KRÉTA servers and was a member of the eKRÉTA – Database group, as well as having access to the [...] server as a member of the Database Team.

105. As soon as the Obligor became aware of the attack in September 2022, it immediately replaced the affected user's machine and deactivated both the original user account and the various permissions, then created a new user account for them. At the same time, the affected user synchronized the login data (usernames and passwords) for both their old and new accounts to a password manager provided as a service by Google Ireland Ltd. (hereinafter: Google), except – according to their statement – for the login data required for NISZ access. The Google password manager works in such a way that the user can save the usernames and passwords necessary to access applications and systems available on other websites in their own Google account. If unauthorized individuals gain access to a user's Google account that stores their passwords in this manner, they can discover all usernames and passwords stored there. Through the synchronization provided by the password manager, if the user enters a different, new password for another website or system compared to what has already been saved, the Google password manager can store this, effectively overwriting the old password with the new one. The attackers could still access the affected user's Google account through an open session, thereby obtaining the passwords for all systems belonging to the Obligor that were also stored in the password manager. The use of the Google password manager thus posed an unmanaged risk to the security of the data stored in the KRÉTA system. The attackers could have already logged into the affected user's Google account before they received a new user account and password for the KRÉTA system, and could have remained logged in thereafter, thanks to the continuous open connection (session) between Google's server and the attackers' computer. Consequently, merely creating a new user account for the KRÉTA system in this case could not have been a sufficient step, as its password was synchronized by the Google password manager following the first successful login by the affected user. According to the Authority's position, for an employee performing such activities, both the synchronization of passwords with Google and the fact that the session is not automatically logged out constitute serious data security flaws, which unacceptably increased the system's exposure, as there are password management software solutions installed only on the specific computer that can securely store users' passwords, like a safe. The passwords stored in these software solutions are generally only accessible through the user's two-factor authentication or extremely strong (i.e., sufficiently long,

22

password (which requires the inclusion of numbers, both lowercase and uppercase letters, as well as special characters) is accessible.

106. Therefore, the attacker - as acknowledged by the Obligor - gained access to the affected user's permissions, and consequently, it can be established that the attacker could also access the data stored in the live KRÉTA system. The fact that the attacker specifically became aware of the personal data stored in the live KRÉTA system could not be proven during the proceedings, considering that if the attacker logged into the live KRÉTA system, they did so with valid permissions, those of the affected user, thus the actions of the attacker cannot be separated from those of the affected user based solely on browsing the log files. It can, however, be treated as a fact that the attacker had the opportunity to access the data stored in the live KRÉTA system. The Obligor did not rule out this possibility in their responses. It is worth mentioning the information cited by the Obligor (see paragraph 46), stating that an external state-owned contractor is conducting an investigation for the Obligor until the end of December 2023, which includes a search for data related to KRÉTA system users on the so-called dark web. In this regard, the Authority emphasizes that even if this search were to conclude

that the personal data of KRÉTA system users is not found on the dark web, it would not serve as evidence that the attackers did not extract personal data from the KRÉTA system, as it is not a given that attackers will later publish any information they may have obtained during the attack.

107. A key element of the facts is that the Obligor only set up two-factor authentication for accessing the live KRÉTA system on November 10, 2022, as mentioned in paragraph 32 of this decision.

Two-factor authentication (2FA) is a security method for identity and access management that requires two forms of identification to access resources and data. Two-factor authentication enables businesses to monitor and protect their most vulnerable information and networks. Due to the lack of two-factor authentication, if a username and password pair is known by an unauthorized person, such unauthorized individuals can successfully log into certain systems. Therefore, it is generally considered good practice to use a second factor in addition to the password as a "factor" – for example, sending a one-time code via SMS or using a hardware identifier (so-called token). While a password can be "guessed" with enough attempts, meaning it can be reverse-engineered, a short-lived code or a hardware token possessed only by the authorized person cannot.

108. Due to the obligation to ensure a level of data security commensurate with the degree of risk, the requirement for data security must be strictly enforced in a system such as the Obligor's development environment, since – although personal data from the live KRÉTA system is also stored there in connection with support activities, and not in small numbers – the database of the live KRÉTA system can be easily accessed from there for task performance, which contains a large amount of personal data concerning a significant number of affected individuals, as detailed above.

109. The fact that the incident in question occurred, and that the Obligor did not become aware of its severity on their own but only through the attacker's message, more than a month and a half after the security breach, is significant evidence that the general data protection regulation's data security requirements were not adequately met by the Obligor.

110. During the investigation of the phishing attack detected in mid-September 2022, the Authority's position is that the Obligor - immediately following the detection of the attack in September 2022 -

23

the comprehensive assessment of information security risks related to the affected employee was not conducted, and the response measures were almost exhausted in merely deleting the specific user account and suspending the affected user's permissions. If this investigation had been carried out with due diligence—especially considering the quantity and sensitivity of personal data stored in the live KRÉTA system—the Obligor should have monitored at least the network traffic related to the affected user for a prolonged period, following information security best practices, and should have examined, with the involvement of the given user, which traffic could be linked to their activities and which belonged to unknown—thus presumably unauthorized—users. This would have been necessary also because the Obligor did not have sufficient information regarding whether unauthorized access had occurred, thus a thorough investigation of the causes and potential consequences of the event would have been expected from them. Had this been done, the Obligor would likely have timely detected that unauthorized individuals were present in their systems, as well as precisely what they had access to, and thus could have likely prevented further escalation of the situation.

111. The above clearly highlights a key element of the facts, namely why it would have been of paramount importance and could have prevented the incident if access to the systems used in the Obligor's IT development environment—at least those containing personal data—had required two-factor authentication even at the time of the attack, and that the Obligor should not have only implemented two-factor authentication for accessing the live KRÉTA system in November 2022.

112. It can also be established that the logging conducted by the Obligor regarding the activities of its employees proved to be insufficient for the investigation of the incident, as—just as occurred in this case—if an attacker gained access to an employee's profile, from that point on the attacker could do anything, including extracting all data (including the data in the live KRÉTA system in this case); the

attacker's activities could no longer be separated from the activities of the owner of the hacked profile. This represents a serious data security deficiency, as such logging makes it impossible to comply with the requirements set forth in Article 32(1)(b) and Article 32(2) of the General Data Protection Regulation. The Authority reiterates that the Obligor did not present any information during the proceedings that would have had probative value regarding whether data was not extracted from the live KRÉTA system during the attack.

113. Consequently, it can be clearly established that a minimum requirement for the development of a KRÉTA-level system is two-factor authentication, as well as the existence of sufficiently detailed logging for the investigation of any potential security incident. The Authority is not concerned with the exact records contained in the log files conducted by the Obligor, but rather whether the security event can be sufficiently uncovered based on these records. The answer to this latter question is negative in the present case, and two-factor authentication was only implemented after the attack, which significantly contributed to the success of the attack, as well as to the Obligor's inability to timely recognize the fact and extent of unauthorized access, and thus to timely initiate the implementation of risk-reducing measures.

114. The Authority firmly disagrees with the Obligor's position that the incident was merely due to the negligence of one of its employees, and therefore cannot be traced back to serious data security issues. Although the direct trigger of the incident was indeed employee error, with appropriate data security measures, this would not have led to the consequences described in the case. The Obligor's own position contradicts this.

24

that following the awareness of the incident in November 2022, a significant number of (nearly twenty!) system-level changes were implemented, which are of fundamental importance and are expected according to the state of technology (see paragraph 76), whereas if it truly believed that an employee's negligence was merely the trigger of the incident, there would have been no reason for this. Although increasing user awareness is indeed expected from a company of the size of the Obligor, since no business can rely on the assumption that its employees 'will not make mistakes', this only constitutes a small, albeit important, slice of potential data security measures; other data security measures are also necessary, as demonstrated by the measures subsequently taken by the Obligor, which are detailed in paragraph 76.

115. In light of the above, the Authority finds that the Obligor has failed to comply with its obligations under Article 32(1)(b) and Article 32(2) of the General Data Protection Regulation by not adequately considering the risks arising from data processing that could result in the unauthorized disclosure of personal data or unauthorized access to such data during the data security settings of its IT development environment, and as a result, it did not guarantee the continuous confidentiality, integrity, availability, and resilience of the systems and services used for the processing of personal data.

Handling, Risk Classification, and Reporting of the Data Protection Incident

116. According to Article 4(12) of the General Data Protection Regulation, a "data protection incident" is defined as a security breach that results in the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

117. In the investigation of a data protection incident, the evaluation of the steps taken during the handling of the incident is inseparable from the data security settings of the data controller/data processor's systems and the specific characteristics of the data security environment. Since the incident in question would not have occurred with an adequate data security background, the following findings should be interpreted in light of the Authority's earlier statements regarding data security.

118. The Authority primarily assesses the severity of data protection incidents based on the level of risk posed by the security breach to the rights and freedoms of the affected natural persons. Overall, in line with the previously stated points, it can be concluded that a business developing a system like the

KRÉTA system (which contains personal data of millions of natural persons, amounting to tens of millions of data entries, see paragraph 61) and having access to the data stored therein, as described in paragraphs 59-60, must take and investigate even the slightest indication of a security breach as seriously as possible, especially when the possibility/chance of an attack arises in relation to a profile that can also be accessed through the live KRÉTA system.

119. According to Article 32(1) of the General Data Protection Regulation, the data controller and the data processor shall implement appropriate technical and organizational measures to ensure a level of data security appropriate to the risk, taking into account the state of science and technology and the costs of implementation, as well as the nature, scope, circumstances, and purposes of the data processing, and the varying likelihood and severity of the risks to the rights and freedoms of natural persons.

25

120. The lack of two-factor authentication and the deficiencies in logging performed by the Obligor, as detailed above, are in no way consistent with the state of science and technology in the development environment. The amount of personal data stored in the system developed by the Obligor, and in some cases saved during support activities, clearly defines the nature and scope of data processing. In the case of developing such a system, it is a minimum expectation that all reasonably available data security measures in accordance with the latest state of science and technology must be implemented. The data security measures taken by the Obligor following the occurrence of the incident, as detailed in paragraph 76, were deemed adequate by the Authority; however, this only supports the fact that the Obligor is aware of the level and nature of data security measures that would be expected for a system like the one it is developing, yet this incident had to occur for these measures to be realized.

121. Based on the personal data to which access occurred or could have occurred by the attacker, the data protection incident at the Obligor can be interpreted on two levels according to the Authority's position:

122. The first level of the incident: The attack demonstrably affected the personal data that the affected user saved on their machine in connection with support activities, as well as the data of the Obligor's employees (see paragraphs 45-46). In this case, due to the high number of affected individuals and the large amount of affected personal data, a high-risk data protection incident has demonstrably occurred.

123. The second level of the incident: Potential access to personal data in the live KRÉTA system by the attacker. In this regard, the above section of the decision analyzing the Obligor's data security settings contained findings, but the Authority wishes to emphasize again that the Obligor did not present any information during the proceedings that would unequivocally prove that the attacker did not extract personal data from the live KRÉTA system. According to the Authority's position, based on the information uncovered during the proceedings, it can be reasonably concluded that personal data stored in the live KRÉTA system was also accessed during the attack. Therefore, the occurrence of a high-risk data protection incident in this case is likely.

124. In its response, the Obligor stated that the attack against it likely occurred on September 15, 2022, when the affected employee opened the infected element, a phishing message. Based on the details in paragraph 40, on September 19, 2022, the affected user reported the problem to their superior and the operations group leader; therefore, the Authority considers this day as the date of becoming aware of the data protection incident. Although the Obligor was unable to assess the actual extent and consequences of the attack at that time, it was already aware that it had fallen victim to a phishing attack, and thus, with due diligence, it should have at least presumed the possibility of the consequences mentioned in the previous two paragraphs. The Authority cannot evaluate in favor of the Obligor that it did not make this presumption due to its own negligence and was unable to conduct an internal investigation that could have confirmed the extent of the attack as early as September 2022, which, in fact, was not a difficult-to-detect, sophisticated attack due to being a phishing attack.

125. Since, according to the Authority's assessment, the Obligor became aware of at least the data

protection incident mentioned in paragraph 122 on September 19, 2022, it was obliged, under Article 33(2) of the General Data Protection Regulation, to report it to the data controllers without undue delay following its awareness, meaning in this case to the 12.

26

institution (see paragraph 45), to which personal data had been saved in the context of support activities on the affected user's machine.

126. Summarizing the circumstances of the incident mentioned above, it is demonstrable that, for interconnected reasons, a high-risk incident occurred on the part of the Obligor, and it is likely that an exceptionally high-risk incident also occurred. Although the assessment of the risks of data protection incidents is typically the responsibility of the data controller, in this case, due to the nature of the KRÉTA system and the development environment, the Obligor, as the data processor, was only in a position to assess the risks of the incident with knowledge of all its circumstances.

127. In light of the above, the Authority finds that the Obligor violated Article 33(2) of the General Data Protection Regulation, as it failed to report a data protection incident, in connection with which
a) the fact of the attack (the affected user clicked on the link in the phishing message) was already known to the Obligor on September 19, 2022,

b) regarding the success of the attack and its consequences - based on the nature and scope of the system - it could have reasonably ensured through appropriate investigative measures that it was aware of the situation without undue delay.

The applied sanction and its justification

128. During the clarification of the facts, the Authority established that the Obligor, in the course of its data processing,

- violated Article 32(1)(b) and Article 32(2) of the General Data Protection Regulation,
- violated Article 33(2) of the General Data Protection Regulation.

129. The Authority examined whether it was justified to impose a data protection fine on the Obligor. In this regard, the Authority considered all circumstances of the case based on Article 83(2) of the GDPR and Section 75/A of the Infotv.

130. In this regard, the Authority decided, based on Section 61(1)(a) of the Infotv., as stated in the operative part, and also obliged the Obligor to pay a data protection fine in this decision.

131. In imposing the fine, the Authority took the following factors into account:

132. The Authority considered the following as aggravating circumstances:

133. The processing of data affected by the incident carries an exceptionally high risk due to the quantity and nature of the data (see paragraphs 59-61), therefore the Obligor should have acted with increased caution to ensure a level of data security commensurate with the degree of risk.

Nevertheless, the Obligor did not take appropriate measures prior to the incident to ensure the continuous confidentiality of the system used for processing a large amount of personal data affecting a significant number of data subjects. The violation would not have occurred at all, or could have been remedied as early as September 2022, had the expected data security measures been in place.

However, based on the established facts, the recognition of the severity of the incident and the actual extent of the data security deficiencies only occurred in November 2022 (Article 83(2)(a) and (g) of the General Data Protection Regulation).

27

134. The Authority established, based on the facts revealed, that the liable party's attributable negligent behavior led to the aforementioned violations. The liable party should have anticipated external attacks due to the recognition of the system it developed and the volume of personal data stored within it. The obligation to implement the technical and organizational measures mentioned in Article 32 of the General Data Protection Regulation was also defined to prevent the success of IT attacks. However, the fact that the measures described in paragraph 76 were only introduced after the

incident occurred indicates that the liable party recklessly relied on the absence of attacks and applied data security measures that were inadequate for eliminating and detecting unauthorized access in a fundamentally high-risk data processing context, disproportionate to the risks involved. The security preparedness for the processing of personal data of the category and quantity mentioned in paragraphs 59-61 is expected to be heightened from the liable party, as a profit-oriented enterprise (Article 83(2)(b), (c), and (d) of the General Data Protection Regulation).

135. The liable party has no further influence over what the attacker does with the personal data acquired during the attack, and this circumstance gives rise to a significant degree of uncertainty regarding the further fate of the personal data (Article 83(2)(a) of the General Data Protection Regulation).

136. The Authority became aware of the data protection incident not through the liable party but based on news reports published in the media (Article 83(2)(h) of the General Data Protection Regulation).

137. The Authority took the following mitigating circumstance into account:

138. The Authority considered that no similar violation regarding the processing of personal data had previously been established against the liable party, nor had any of the measures mentioned in Article 58(2) of the General Data Protection Regulation been ordered against it in the same matter (Article 83(2)(e) and (i) of the General Data Protection Regulation).

139. Other circumstances:

140. The Authority also noted that the liable party cooperated with the Authority during the investigation of the case, although this behavior was not specifically evaluated as a mitigating circumstance since it did not exceed compliance with legal obligations (Article 83(2)(f) of the General Data Protection Regulation).

141. Article 83(2)(j) of the General Data Protection Regulation was not relevant in this case.

142. In light of the above, the Authority deemed it necessary to impose a fine, considering that merely applying a warning under Section 75/A of the Infotv. was not deemed appropriate.

143. The amount of the data protection fine was determined by the Authority exercising its discretion based on legal provisions.

144. The violations committed by the liable party are classified as violations falling under the penalty category specified in Article 83(4)(a) of the General Data Protection Regulation.

145. In imposing the fine, the Authority also considered the economic weight of the liable party. In this context, it took into account that, according to the liable party's report, between January 1, 2022, and December 2022...

28

31. Between the 31st day, the net revenue was 8,429,507,000 HUF (eight billion four hundred twenty-nine million five hundred seven thousand forints).

146. Considering the severity of the infringement and the above economic data of the Obligor, the amount of the imposed fine is deemed proportionate to the severity of the infringement according to the Authority's assessment.

IV. Other Issues

147. The Authority's jurisdiction is defined by Section 38 (2) and (2a) of the Infotv., and its competence extends to the entire territory of the country.

148. Based on Section 112 and Section 116 (1), as well as Section 114 (1) of the Ákr., there is a legal remedy available against the decision through administrative litigation.

149. The rules of administrative litigation are defined by Act I of 2017 on Administrative Litigation (hereinafter: Kp.). According to Section 12 (1) of the Kp., administrative litigation against the Authority's

decision falls under the jurisdiction of the court, and based on Section 13 (3) point a) subpoint aa) of the Kp., the Metropolitan Court is exclusively competent for the case. According to Section 27 (1) point b) of the Kp., legal representation is mandatory in cases falling under the jurisdiction of the court. According to Section 39 (6) of the Kp., the submission of the statement of claim does not have a suspensive effect on the enforcement of the administrative act.

150. According to Section 29 (1) of the Kp. and in consideration of this, Section 604 of the Pp. applies, and according to Section 9 (1) point b) of Act CCXXII of 2015 on the General Rules of Electronic Administration and Trust Services (hereinafter: E-ügyintézési tv.), the client's legal representative is obliged to maintain electronic communication.

151. The time and place for submitting the statement of claim are determined by Section 39 (1) of the Kp. Information regarding the possibility of requesting a hearing is based on Sections 77 (1)-(2) of the Kp. The amount of the administrative litigation fee is determined by Section 45/A (1) of Act XCIII of 1990 on Fees (hereinafter: Itv.). The party initiating the proceedings is exempt from the preliminary payment of the fee under Section 59 (1) and Section 62 (1) point h) of the Itv.

152. According to Section 132 of the Ákr., if the obligor does not comply with the obligation set forth in the Authority's final decision, it is enforceable. The Authority's decision becomes final upon communication according to Section 82 (1) of the Ákr. According to Section 133 of the Ákr., the enforcement is ordered by the authority that made the decision, unless otherwise provided by law or government decree. According to Section 134 of the Ákr., the enforcement is carried out by the state tax authority unless otherwise provided by law, government decree, or a local government regulation in a local government authority matter. Based on Section 60 (7) of the Infotv., the enforcement of the decision regarding the performance of a specific act, conduct, tolerance, or cessation specified in the Authority's decision is carried out by the Authority.

Dated: [according to electronic signature]

Dr. habil. Attila Péterfalvi
President
Professor Emeritus